

Инсайдерская угроза: Моделируем атаку «изнутри». Как Red Team имитирует злонамеренного сотрудника

 redsec.by/article/insajderskaya-ugroza-modeliruem-ataku-iznutri-kak-red-team-imitiruet-zlonamerennogo-sotrudnika

Red Teams | 23 января 2026



В современной парадигме кибербезопасности принято считать, что периметр уже прорван. Классический пентест (Penetration Testing) исторически ориентирован на имитацию внешнего врага — хакера, который штурмует крепостные стены, пытаясь найти уязвимость в межсетевом экране или веб-приложении. Однако сухая статистика и реальный опыт инцидент-респонса (IR) убедительно доказывают обратное: враг часто уже находится внутри.

Инсайдеры представляют собой угрозу, сравнимую по масштабу с APT-группировками, а зачастую и превосходящую их. Данные аналитических отчетов за 2024–2025 годы рисуют тревожную картину: **76% организаций** зафиксировали рост частоты инсайдерских атак. Средняя стоимость одного такого инцидента достигла колоссальных **\$17,4 млн в год**.

Почему это происходит? Потому что традиционные средства защиты (FW, WAF, IPS) смотрят «наружу». Инсайдер же работает в доверенной зоне, использует легитимные учетные записи и маскируется под нормальную бизнес-активность. 90% специалистов по безопасности подтверждают: инсайдерскую атаку сложнее всего обнаружить.

В этой статье мы разберем, как Red Team моделирует инсайдерские угрозы. Мы не просто будем говорить о теории, а проведем операцию «изнутри»: покажем конкретные сценарии, технические приемы (TTPs), код для закрепления в системе и методы, которые позволяют Blue Team (защитникам) выявлять эти аномалии.

Статистика: Масштаб проблемы в цифрах

Прежде чем переходить к технике, взглянем на цифры, которые делают эту проблему приоритетной для CISO.

Показатель	Значение	Комментарий
Рост частоты инсайдерских атак	76%	Организаций отметили увеличение количества кейсов
Экfiltrация данных (2023–2024)	+28%	Рост попыток выноса данных за периметр
Средняя стоимость инцидента	\$17,4 млн	Совокупные потери в год
Небрежность / Ошибки	55%	Ущерб: ~\$8,8 млн. Человеческий фактор
Злонамеренные инсайдеры	25%	Умышленные действия (шпионаж, саботаж)
Среднее время обнаружения	81 день	Почти 3 месяца злоумышленник находится в сети
Организации без инцидентов (2024)	17%	В 2023 году таких было 40%. Тренд негативный

Важно отметить распределение: 55% инцидентов — это работа «небрежных» инсайдеров, которые случайно компрометируют систему. Но наиболее разрушительными являются 25% умышленных действий. Их выявление часто запаздывает на месяцы, так как злоумышленник знает, как обойти триггеры безопасности.

Типология инсайдерских угроз: Три вектора для Red Team

При разработке сценариев учений Red Team мы опираемся на психологический и технический профиль нарушителя. В индустрии выделяют три канонических архетипа.

1. Злонамеренный инсайдер (Malicious Insider)

Это классический «предатель».

- **Мотивация:** Финансовая выгода (продажа данных), месть работодателю, кража интеллектуальной собственности для перехода к конкуренту.
- **Действия:** Осознанная эксфильтрация баз данных, саботаж инфраструктуры, установка закладок.
- **Пример:** Системный администратор, продающий дампы клиентской базы в DarkNet, или специалист по расчетам, ворующий ПДн коллег.

2. Небрежный инсайдер (Negligent Insider)

Угроза без злого умысла, но с фатальными последствиями.

- **Мотивация:** Отсутствует; корень проблемы — низкая цифровая грамотность или халатность.
- **Действия:** Обход политик безопасности «ради удобства», отправка рабочих файлов на личный Gmail, запись паролей на стикерах, клик по фишинговым ссылкам.
- **Пример:** Сотрудник, выложивший конфиденциальный отчет на общедоступный Google Drive.

3. Скомпрометированный инсайдер (Compromised Insider)

Технически — это жертва.

- **Мотивация:** Отсутствует у сотрудника, но есть у внешнего хакера.
- **Действия:** Учетная запись сотрудника используется внешним злоумышленником. Сам сотрудник продолжает работать, не подозревая о «соседе».
- **Пример:** Жертва фишинга или сотрудник, чей пароль был найден в публичной утечке (Creds Stuffing).

Для Red Team наибольший интерес представляют сценарии №1 и №3. Они сложнее всего обнаруживаются, наносят максимальный ущерб и требуют комплексного подхода к эмуляции.

Сценарий 1: «Обиженный админ»

Профиль атаки: Что может сделать привилегированный пользователь?

Это «Кошмарный сценарий» для любой компании. Мы моделируем действия системного администратора, который:

- Узнал о грядущем увольнении или понижении.
- Испытывает острую обиду на руководство.

- Обладает правами *Domain Admin* или *Enterprise Admin*.
- Имеет доступ к бэкапам и может работать в ночную смену, когда бдительность SOC снижена.

Реальный кейс: Инженер, получивший доступ к старому отчету по пентесту через социальную инженерию, использовал найденные там учетные данные для создания логической бомбы, удаляющей пользователей Active Directory в момент его увольнения.

Фаза 1: Разведка и планирование (Reconnaissance)

Даже обладая правами, «Обиженный админ» действует осторожно. Red Team в этой роли отвечает на вопросы:

- Какие системы критичны для бизнеса? (Контроллеры домена, ERP, CRM).
- Есть ли «слепые зоны» в мониторинге? (Где не стоит EDR?).
- Как обеспечить доступ после блокировки основной учетной записи?

Техники MITRE ATT&CK:

- **T1087** — Account Discovery (инвентаризация аккаунтов).
- **T1087.004** — Domain Account.
- **T1526** — Cloud Service Discovery.

Фаза 2: Установка персистентности (Persistence)

Зная о неизбежном увольнении, администратор оставляет «закладки» (Backdoors).

Техника 1: Создание скрытой учетной записи

Атакующий создает пользователя, имитирующего сервисную учетную запись, чтобы не вызывать подозрений при беглом просмотре списка пользователей.

```
# Создать учётку с именем, похожим на системный сервис обновления
net user sysupd$ p@ssw0rd /add
```

```
# Скрытно добавить пользователя в группу Domain Admins
net group "Domain Admins" sysupd$ /add /domain
```

- **Цель:** Даже если HR заблокирует основного пользователя admin_ivanov, учетная запись sysupd\$ останется активной. Знак \$ часто используется для машинных аккаунтов, что сбивает с толку неопытных админов.
- **Обнаружение:** SIEM должен реагировать на Event ID **4720** (New User Created). Создание пользователей вручную, особенно с правами администратора — критический алерт.

Техника 2: Модификация Group Policy Objects (GPO)

Админ может использовать групповые политики для массового воздействия на инфраструктуру:

- Отключение Windows Defender на рабочих станциях.
- Создание Scheduled Task, восстанавливающей доступ.
- Развертывание Logon-скриптов с вредоносной нагрузкой.

MITRE ATT&CK: T1484.001 — Domain Policy Modification.

Обнаружение: Event ID **5136** на контроллере домена логирует изменения объектов AD. Любая модификация GPO в нерабочее время должна расследоваться.

Техника 3: Атака на сертификаты (AD CS)

Если используется Active Directory Certificate Services, это золотая жила для инсайдера.

- Админ запрашивает сертификат от имени другого пользователя (например, CIO или другого Domain Admin).
- Использует сертификат для аутентификации (Pass-the-Certificate).

MITRE ATT&CK: T1550.003 — Use Alternate Authentication Material.

Обнаружение: Мониторинг Event ID **4886** и **4887**. Красный флаг: поле RequestorName не совпадает с SubjectName, при этом запрашиваются высокие привилегии.

Фаза 3: Покрытие следов и Экфилтрация (Exfiltration & Defense Evasion)

После закрепления наступает фаза активных действий.

- Дамп баз данных клиентов.
- Копирование исходного кода.
- Удаление ключей шифрования.

Для сокрытия следов инсайдер чистит логи:

```
:: Полная очистка логов безопасности  
wevtutil cl Security
```

Или оставляет «прощальный подарок» (Logic Bomb):

```
# Запланированная задача, которая сработает при следующем входе  
$trigger = New-ScheduledTaskTrigger -AtLogon  
$task = New-ScheduledTask -Trigger $trigger -Action (New-ScheduledTaskAction -Execute  
Register-ScheduledTask -TaskName "System Maintenance" -InputObject $task
```

Обнаружение:

- **EDR:** Должен блокировать и алертировать процессы, использующие wevtutil или Get-EventLog с флагом -Clear.
- **UEBA:** Детектирует аномальный объем скачиваемых данных (Spike in outbound traffic) и активность в нерабочие часы.

Чек-лист Red Team для Сценария 1

Вопрос	Что проверяем	Техника MITRE
Обнаруживаются ли скрытые «сервисные» учетки?	EDR, SIEM, UEBA	T1136 — Create Account
Мониторятся ли изменения в GPO?	Event logs, SIEM	T1484.001
Заметны ли запросы сертификатов для других лиц?	ADCS logs	T1550.003
Отслеживается ли очистка логов?	File Integrity Monitoring	T1070 — Indicator Removal
Выявляется ли экспорт гигабайтов данных?	DLP, NDR, UEBA	T1020 — Exfiltration Over C2

Сценарий 2: «Любопытный бухгалтер»

Профиль атаки: Несанкционированный доступ без прав администратора

В этой роли Red Team имитирует сотрудника финансового департамента или HR.

- **Доступ:** Ограниченный (видит свои документы, но не имеет прав администратора).
- **Психология:** Любопытство («сколько получает гендиректор?», «какая реальная прибыль?»).
- **Слабость:** Подвержен социальной инженерии, не соблюдает цифровую гигиену.

Хотя этот сценарий часто классифицируют как «небрежность», мы используем его для проверки внутренней сегментации сети и прав доступа.

Фаза 1: Поиск слабых мест (Discovery)

Техника 1: Перечисление общих папок (Share Enumeration)

Пользователь сканирует сеть в поисках открытых ресурсов.

```
# Поиск всех доступных сетевых шар
net share
net view \\servername
```

Что ищем: Часто администраторы создают папки вида \\FS-01\Archive\ или \\FS-01\Backup\, забывая ограничить к ним доступ. Внутри можно найти:

- Забытые дампы баз данных.
- Excel-файлы с паролями («passwords.xlsx»).
- SSH-ключи или конфиги VPN.

MITRE ATT&CK: T1552.001 — Credentials in Files.

Обнаружение: UEBA должна фиксировать, когда бухгалтер начинает обращаться к сетевым ресурсам, не связанным с его должностными обязанностями (Lateral Movement).

Техника 2: Социальная инженерия (Internal Phishing)

Бухгалтер звонит в IT-поддержку: *«Мне срочно нужен доступ к папке \\FS-01\Reports\Board, горит годовой отчет!»*. Часто уставший администратор выдает права, не проверяя авторизацию, и забывает их отозвать.

MITRE ATT&CK: T1566 — Phishing.

Техника 3: Латеральное движение через базы данных

Доступ к одной базе часто открывает путь к другим, если сервер администрируется плохо. Пример: Бухгалтер имеет доступ к SQL Server для работы с 1С, но на том же инстансе крутится база HR.

```
# Подключение к SQL Server (если аутентификация смешанная или слабая)
sqlcmd -S SERVERNAME\SQLINSTANCE -U sa -P password123
```

```
# Прямой запрос к таблице, к которой доступ должен быть закрыт
SELECT * FROM HR_Payroll.Employees WHERE Salary > 0
```

Обнаружение: Network monitoring должен выявлять SQL-трафик с рабочих станций пользователей, которые обычно не делают прямых запросов к БД.

Фаза 2: Эксплуатация данных

Как вынести данные, если USB-порты заблокированы (или нет)?

- **USB:** Если DLP не настроен жестко, копирование на флешку — самый простой путь.
- **Email:** Отправка самому себе на личный ящик.
- **Облака (Shadow IT):** Загрузка на Google Drive, Яндекс.Диск или DropBox.

Обнаружение:

- **CASB (Cloud Access Security Broker):** Мониторинг загрузок в личные облака.
- **DLP:** Блокировка передачи файлов с метками конфиденциальности.
- **NDR:** Детектирование DNS-запросов к облачным хранилищам (например, drive.google.com) в больших объемах.

Чек-лист Red Team для Сценария 2

Вопрос	Что проверяем	Техника MITRE
Есть ли избыточные права на сетевые папки?	Share enumeration	T1552 — Unsecured Credentials
Как работает валидация запросов доступа?	Social Engineering	T1566 — Phishing
Защищены ли базы данных от перебора?	SQL Brute-force	T1110 — Brute Force
Блокируется ли отправка на личный email?	Email Gateway	T1020 — Data Exfiltration
Видны ли загрузки в облако?	CASB, UEBA	T1567 — Exfiltration Over Web Service

Сценарий 3: «Случайный пособник» (Compromised Insider)

Профиль атаки: Внешний хакер внутри периметра

Самый опасный и распространенный сценарий. Обычный сотрудник:

- Кликнул по фишинговой ссылке.
- Использовал корпоративный пароль на стороннем сайте, который был взломан.
- Его ноутбук заражен через Drive-by загрузку.

Теперь злоумышленник (Red Team) действует от его имени. Отличие от инсайдера в том, что поведение может резко измениться (работает быстрее, использует скрипты).

Фаза 1: Первоначальный доступ (Initial Access)

Вектор 1: Целевой фишинг (Spearphishing) Письмо от якобы IT-отдела:

«Внимание: обнаружена утечка паролей. Срочно смените пароль на портале: `update-company.local/reset`»

Сотрудник вводит данные, Red Team их перехватывает. **MITRE ATT&CK: T1566.002** — Spearphishing Link.

Вектор 2: Password Spraying

Использование баз утечек (Have I Been Pwned). Если сотрудник john.doe использует пароль Password123! везде, Red Team пробует его на VPN и Outlook.

Фаза 2: Латеральное движение (Lateral Movement)

Red Team получил доступ как john.doe. Что дальше?

Этап 1: Разведка сети

```
# Что видит пользователь?
net user john.doe /domain
Get-ADUser john.doe -Properties MemberOf
```

```
# Поиск машин в домене
net view /domain
```

Мы узнаем, что John входит в группы «Finance» и «VPN Users», а в сети есть серверы FS-01, SQL-01.

Этап 2: Поиск привилегий (Privilege Escalation)

Мы ищем пути повышения прав до администратора.

```
# Поиск доверительных отношений
nltest /domain_trusts

# Атака Kerberoasting: запрос билетов для сервисных аккаунтов
# Цель: получить хэш пароля сервисной учетки, взломать его оффлайн
GetUserSPNs.py -request company.local/john.doe:password
```

MITRE ATT&CK:

- **T1087.002** — Account Discovery.
- **T1558.004** — Steal or Forge Kerberos Tickets (Kerberoasting).

Фаза 3: Эскалация до Domain Admin

Если Red Team находит уязвимость (например, пароль админа в текстовом файле на общей шаре или уязвимость в AD CS), происходит захват домена.

```
# Запуск процесса от имени найденного админа
runas /user:domain\admin powershell
```

```
# Добавление скомпрометированного пользователя в администраторы
Add-ADGroupMember "Domain Admins" -Members john.doe
```

Фаза 4: Персистентность и Вывод данных

После получения полного контроля, тактика совпадает со Сценарием 1: установка бэкдоров, скрытых учеток и массовая выгрузка данных.

Чек-лист Red Team для Сценария 3

Вопрос	Что проверяем	Техника MITRE
Люди кликают на фишинг?	Phishing simulation	T1566
Срабатывает ли MFA при входе с нового IP?	MFA Bypass Test	T1111
Мониторятся ли неудачные попытки входа?	Log Analysis	Anomaly Detection
Обнаруживается ли Kerberoasting?	Honeytokens / SIEM	T1558
Видна ли передача хакерских утилит внутри сети?	Network Monitoring	T1570 — Lateral Tool Transfer

Детектирование: Роль UEBA и EDR

Почему классические антивирусы здесь бессильны? Они ищут сигнатуры (известные вирусы). Инсайдер же использует легитимные инструменты (powershell, net.exe, wevtutil).

User and Entity Behavior Analytics (UEBA)

UEBA — это «мозг» защиты от инсайдеров. Система строит профиль *нормального* поведения для каждого сотрудника и бьет тревогу при отклонениях.

Примеры детектируемых аномалий:

Аномалия	Пример ситуации	Риск
Off-hours access	Финансист логинится в 3 часа ночи	Экфильтрация / Кража
Unusual data volume	Скачано 50 ГБ вместо обычных 50 МБ	Дамп базы данных
Access outside role	Бухгалтер читает логи серверов	Lateral Movement
New cloud service	Первая загрузка на Google Drive	Утечка данных
Location mismatch	Вход из двух стран за 1 час	Компрометация учетки

Endpoint Detection & Response (EDR)

EDR следит за процессами на конечных точках. В контексте инсайдера EDR должен ловить специфические техники:

- **Privilege Escalation:** Создание пользователя с символом \$ (Event ID 4720).
- **Token Abuse:** Попытки доступа к памяти процесса lsass.exe (Dumping credentials).
- **Log Deletion:** Запуск wevtutil.exe или очистка журналов.
- **Exfiltration Tools:** Запуск архиваторов (7-Zip, WinRAR) или облачных утилит (rclone) из необычных директорий.

Фреймворк Red Team операции: От планирования до отчета

Профессиональная симуляция — это не хаос, а структурированный процесс.

Фаза 1: Threat Modeling (2–3 недели)

Определяем «Персону» и «Цепочку атаки» (Kill Chain).

- *Пример:* Disgruntled Admin.
- *Цель:* Выкрасть базу клиентов и обеспечить скрытый доступ.
- *Инструментарий:* PowerShell, GPO, AD native tools.

Фаза 2: Подготовка инфраструктуры (1–2 недели)

- Развертывание C2 (Command & Control) серверов.
- Подготовка фишинговых доменов.

- Настройка OPSEC (Operational Security): инструменты не должны «светиться» как явная малварь.

Фаза 3: Execution (2–4 недели)

Активная фаза.

- **Дни 1–2:** Компрометация (Phishing / Credential Stuffing).
- **Дни 3–5:** Латеральное движение и разведка.
- **Дни 6–8:** Эскалация привилегий.
- **Дни 9–14:** Экфилтрация данных и зачистка следов.

Параллельно Blue Team работает «вслепую» (или в режиме Purple Team), пытаясь обнаружить активность.

Фаза 4: Анализ и Отчет (1 неделя)

Самый важный этап. Red Team раскрывает карты.

- **Timeline:** Поминутная хронология атаки.
- **Gap Analysis:** Что Blue Team пропустил? (Например: «Создание юзера sysupd\$ не вызвало алерта, так как правило игнорирует имена с \$»).
- **Mitigation:** Как закрыть обнаруженные дыры.

Практические рекомендации и соответствие требованиям (ОАС)

Что внедрить прямо сейчас?

- **Принцип наименьших привилегий (Least Privilege):** *Критично.* Никаких локальных админов на рабочих станциях.
- **MFA (Многофакторная аутентификация):** *Критично.* На VPN, почте, облачных сервисах.
- **UEBA:** *Критично.* Без поведенческого анализа инсайдера не поймать.
- **SIEM + Аудит AD:** *Высокий.* Корреляция событий 4720, 4722, 4728, 5136.
- **Сегментация сети:** *Средний.* Пользовательская сеть отделена от серверной и DMZ.

Для организаций, проходящих сертификацию ОАС

Если ваша деятельность регулируется требованиями Оперативно-аналитического центра (актуально для Беларуси и ряда госструктур), Red Team симуляция инсайдера — обязательный элемент compliance.

Требования ОАС включают:

- Идентификацию критических активов.
- Строгий контроль доступа (RBAC).
- Логирование действий привилегированных пользователей.

В рамках аудита ОАС Red Team должен подтвердить:

- Может ли привилегированный пользователь получить доступ к данным без санкции?
- Фиксируются ли попытки повышения привилегий?
- Насколько эффективно работает система защиты от утечек (DLP) при действиях «изнутри»?

Симуляция атаки инсайдера силами Red Team — это не академическое упражнение, а стресс-тест жизненно важных систем организма компании. Рассмотренные нами сценарии — «Обиженный админ», «Любопытный бухгалтер» и «Скомпрометированный сотрудник» — демонстрируют, что периметр больше не является гарантией безопасности.

Когда 76% организаций фиксируют рост внутренних инцидентов, а среднее время их обнаружения составляет 81 день, полагаться только на удачу — преступная халатность. Внедрение UEBA, грамотная настройка SIEM/EDR и регулярные киберучения ("War Games") — это единственный способ увидеть невидимую угрозу до того, как она нанесет непоправимый ущерб.